

Prevent Crash. Preserve Cash.

100/100 — Repository Risk Score · CRITICAL RISK

$F = |\langle \psi_t | \psi_m \rangle|^2 = 0.4277$ · UNSAFE DIRECTION (57.2% orthogonal to baseline)

Field	Value
Scan Date	2026-05-18
Repository	https://github.com/OWASP/NodeGoat
Packages Analysed	1479
Findings	165 total (46 critical, 63 high, 56 medium, 0 low)
Quantum F_min (angle)	0.4277 — UNSAFE

This report is confidential. All findings derive from automated real-data analysis. No issues have been invented, extrapolated, or estimated. Quantum fidelity scores use a 4-qubit PennyLane circuit with dual encoding.

TAARA Q.0 | GoodWinSun | Powered by Groq + PennyLane + PQC Kyber768

1. Executive Summary

Metric	Value	Status
Repository Risk Score	100/100	CRITICAL
Critical Findings	46	Immediate action required
High Findings	63	Fix within 1 week
Quantum F_min (angle)	0.4277	CONFIRMED UNSAFE

What This Means for You

On May 18, 2026, TAARA conducted a security assessment of the organisation's infrastructure, scanning 46 total critical vulnerabilities in the NodeGoat repository. The assessment did not include a server evaluation, and instead focused on the repository's packages and dependencies, uncovering a range of significant findings. The scan revealed critical vulnerabilities in packages such as growl, underscore, and handlebars, which are known to be susceptible to command injection, arbitrary code execution, and prototype pollution.

The most critical specific findings include the presence of vulnerabilities in growl v1.9.2, identified by GHSA-qh2h-chj9-jffq, and underscore v1.8.3, identified by GHSA-cf4h-3jhx-xvhq. Additionally, the assessment identified potential exploit chains, including paths through async@2.6.1, which has a score of 10.0 and is associated with GHSA-fwr7-v2mv-hh25, and bson@1.0.9, which has a score of 10.0 and is associated with GHSA-v8w9-2789-6hhr. These specific findings and exploit chains pose a significant threat to the organisation's security.

The quantum behavioral analysis result, with an F_min value of 0.4277, indicates that the assessed system is operating in an unsafe state, with genuine behavioral divergence confirmed. This means that TAARA has detected a correlated attack pattern, suggesting that the organisation's infrastructure is likely under attack or has already been compromised. The low F_min value indicates a high degree of certainty that the detected anomalies are not benign, and that a real threat is present.

The single most urgent action required is to address the vulnerabilities in growl and underscore, by upgrading to the fixed versions, 1.10.0 and 1.12.1, respectively. If left unaddressed, these vulnerabilities pose a significant business risk, as they could be exploited to execute arbitrary code, inject commands, or pollute prototypes, potentially leading to a complete compromise of the organisation's infrastructure and data. The presence of exploit chains through dependencies such as async and bson further amplifies this risk, highlighting the need for immediate remediation to prevent a potentially catastrophic security breach.

Quantum Behavioral Analysis

The F_min value of 0.4277 for the NodeGoat server indicates that its current behavior is significantly different from its established secure baseline, suggesting a potential security issue. Since the amplitude encoding computation was not performed, we cannot determine if it would have missed the behavioral divergence detected by the angle encoding, which found a substantial deviation with an F_min below the 0.5 threshold, implying that the angle encoding was sufficient to raise a red flag. Given the UNSAFE status and confirmed behavioral divergence with an F_min of 0.4277, the next step is to investigate the NodeGoat server's behavior in more detail to identify the root cause of the divergence and take corrective action to bring its behavior back in line with the secure baseline.

2. Repository Vulnerability Findings

46 CRITICAL · 63 HIGH · 56 MEDIUM · 0 LOW · Total: 165 across 1479 packages

TAARA GraphRAG Dependency Risk Analysis

The interdependencies in this application create a significant risk for users, as an attacker could exploit the Prototype Pollution vulnerabilities in `async` and `minimist` to manipulate the application's behavior, potentially leading to arbitrary code execution. The `tar` vulnerabilities, particularly `GHSA-3jfq-g458-7qm9` and `GHSA-5955-9wpr-37jh`, pose a high risk of arbitrary file creation/overwrite, which could allow an attacker to write malicious files to the system. The most urgent packages to fix are `tar` and `fsevents`, as they have multiple critical vulnerabilities with available exploits, and their fixes are relatively recent (e.g., `tar` 4.4.18 and `fsevents` 1.2.11). The presence of transitive dependencies like `bson` and `ms` increases the attack surface, making it essential to address these vulnerabilities promptly to prevent potential exploits.

Analysis alignment: F = 0.661 — Answer direction aligns well with security policy

2.1 Critical Findings — Fix Immediately

Package	Version	CVE	Fix To	Title
growl	1.9.2	GHSA-qh2h-chj9-jff	1.10.0	GHSA-qh2h-chj9-jffq: Growl before 1.10.0 vulnerable to
underscore	1.8.3	GHSA-cf4h-3jhx-xvh	1.12.1	GHSA-cf4h-3jhx-xvhq: Arbitrary Code Execution in unders
set-value	2.0.0	GHSA-4g88-fppr-53p	2.0.1	GHSA-4g88-fppr-53pp: Prototype Pollution in set-value
handlebars	4.0.5	GHSA-w457-6q6x-cgp	4.3.0	GHSA-w457-6q6x-cgp9: Prototype Pollution in handlebars
npm	3.10.10	GHSA-ph34-pc88-72g	5.7.1	GHSA-ph34-pc88-72gc: Incorrect Permission Assignment fo
shelljs	0.3.0	GHSA-4rq4-32rv-6wp	0.8.5	GHSA-4rq4-32rv-6wp6: Improper Privilege Management in s
json-schema	0.2.3	GHSA-896r-f27r-55m	0.4.0	GHSA-896r-f27r-55mw: json-schema is vulnerable to Proto
getobject	0.1.0	GHSA-957j-59c2-j69	1.0.0	GHSA-957j-59c2-j692: Prototype pollution in getobject
lodash	4.17.11	GHSA-p6mc-m468-83g	4.17.19	GHSA-p6mc-m468-83gw: Prototype Pollution in lodash
mixin-deep	1.3.1	GHSA-fhjf-83wg-r2j	1.3.2	GHSA-fhjf-83wg-r2j9: Prototype Pollution in mixin-deep
npm	3.10.10	GHSA-4328-8hgf-7wj	6.13.4	GHSA-4328-8hgf-7wjr: npm Vulnerable to Global node_modu
babel-traverse	6.11.4	GHSA-67hx-6x53-jw9	—	GHSA-67hx-6x53-jw92: Babel vulnerable to arbitrary code
ms	0.7.1	GHSA-w9mr-4mfr-499	2.0.0	GHSA-w9mr-4mfr-499f: Vercel ms Inefficient Regular Expr
minimist	1.2.0	GHSA-xvch-5gv4-984	1.2.6	GHSA-xvch-5gv4-984h: Prototype Pollution in minimist
handlebars	4.0.5	GHSA-765h-qjxv-5f4	4.7.7	GHSA-765h-qjxv-5f44: Prototype Pollution in handlebars
bson	1.0.9	GHSA-v8w9-2789-6hh	1.1.4	GHSA-v8w9-2789-6hhr: Deserialization of Untrusted Data
handlebars	4.0.5	GHSA-xjpi-3mr7-gcp	4.7.9	GHSA-xjpi-3mr7-gcpf: Handlebars.js has JavaScript Injec
handlebars	4.0.5	GHSA-2w6w-674q-4c4	4.7.9	GHSA-2w6w-674q-4c4q: Handlebars.js has JavaScript Injec
hoek	2.16.3	GHSA-jp4x-w63m-7wg	5.0.3	GHSA-jp4x-w63m-7wgm: Prototype Pollution in hoek

Package	Version	CVE	Fix To	Title
async	2.6.1	GHSA-fwr7-v2mv-hh2	3.2.2	GHSA-fwr7-v2mv-hh25: Prototype Pollution in async
npm	3.10.10	GHSA-x8qc-rrcw-4r4	6.13.3	GHSA-x8qc-rrcw-4r46: npm symlink reference outside of n
handlebars	4.0.5	GHSA-xhpf-hc6g-r9c	4.7.9	GHSA-xhpf-hc6g-r9c6: Handlebars.js has JavaScript Injec
fsevents	1.2.9	GHSA-8r6j-v8pm-fqw	1.2.11	GHSA-8r6j-v8pm-fqw3: Code injection in fsevents
lodash	4.17.20	GHSA-35jh-r3h4-6jh	4.17.21	GHSA-35jh-r3h4-6jhm: Command Injection in lodash
			—	EOL runtime: nodejs 12 (1479 days past EOL)

... and 21 more critical findings.

TAARA Analysis — Top Critical Findings

[CRITICAL] growl — GHSA-qh2h-chj9-jffq

An attacker can inject arbitrary system commands by exploiting the vulnerability in Growl before version 1.10.0, allowing them to execute malicious commands on the affected system. To remediate this issue, upgrade the Growl package to version 1.10.0 or later by running the command ``npm install growl@1.10.0`` or ``yarn add growl@1.10.0``.

[CRITICAL] underscore — GHSA-cf4h-3jhx-xvhq

An attacker can execute arbitrary code by manipulating the template function in underscore, allowing them to inject and run malicious code on the targeted system. To remediate this issue, update the underscore package to version 1.12.1 or later by running the command ``npm install underscore@1.12.1`` or ``yarn add underscore@1.12.1``.

[CRITICAL] set-value — GHSA-4g88-fppr-53pp

An attacker can pollute the prototype of an object, allowing them to add or modify properties that can lead to downstream issues such as unintended behavior or code execution. To remediate this issue, update the set-value package to version 2.0.1 or later by running the command ``npm install set-value@2.0.1`` or ``yarn add set-value@2.0.1``.

2.2 High Findings — Fix This Week

Package	Version	CVE	Fix To	Title
minimatch	3.0.4	GHSA-7r86-cg39-jmm	10.2.3	GHSA-7r86-cg39-jmmj: minimatch has ReDoS: matchOne() co
underscore	1.8.3	GHSA-qpx9-hpmf-5gm	1.13.8	GHSA-qpx9-hpmf-5gmw: Underscore has unlimited recursion
hawk	3.1.3	GHSA-44pw-h2cw-w3v	9.0.1	GHSA-44pw-h2cw-w3vq: Uncontrolled Resource Consumption
kind-of	6.0.2	GHSA-6c8f-qphg-qjg	6.0.3	GHSA-6c8f-qphg-qjgp: Validation Bypass in kind-of
minimatch	3.0.4	GHSA-f8q6-p94x-37v	3.0.5	GHSA-f8q6-p94x-37v3: minimatch ReDoS vulnerability
semver	5.7.0	GHSA-c2qf-rxjj-qgg	7.5.2	GHSA-c2qf-rxjj-qggw: semver vulnerable to Regular Expre
minimatch	3.0.4	GHSA-23c5-xmqv-rm7	10.2.3	GHSA-23c5-xmqv-rm74: minimatch ReDoS: nested *() extglo
i	0.3.6	GHSA-x55w-vjjp-222	0.3.7	GHSA-x55w-vjjp-222r: inflect vulnerable to Inefficient
cross-spawn	7.0.3	GHSA-3xgq-45jj-v27	7.0.5	GHSA-3xgq-45jj-v275: Regular Expression Denial of Servi
ansi-regex	3.0.0	GHSA-93q8-gq69-wqm	6.0.1	GHSA-93q8-gq69-wqmw: Inefficient Regular Expression Com
handlebars	4.0.5	GHSA-2qvq-rjwj-gvw	4.7.9	GHSA-2qvq-rjwj-gvw9: Handlebars.js has Prototype Pollut

Package	Version	CVE	Fix To	Title
lodash	4.17.21	GHSA-f23m-r3pf-42r	4.18.0	GHSA-f23m-r3pf-42rh: lodash vulnerable to Prototype Pol
moment	2.24.0	GHSA-8hfj-j24r-96c	2.29.2	GHSA-8hfj-j24r-96c4: Path Traversal: 'dir/../../fi
send	0.16.2	GHSA-m6fv-jmcg-4jf	0.19.0	GHSA-m6fv-jmcg-4jfg: send vulnerable to template inject
qs	5.2.1	GHSA-6rw7-vpxm-498	6.14.1	GHSA-6rw7-vpxm-498p: qs's arrayLimit bypass in its
fstream	1.0.10	GHSA-xf7w-r453-m56	1.0.12	GHSA-xf7w-r453-m56c: Arbitrary File Overwrite in fstrea
sshpki	1.10.1	GHSA-2m39-62fm-q8r	1.13.2	GHSA-2m39-62fm-q8r3: Regular Expression Denial of Servi
brace-expansion	1.1.11	GHSA-f886-m6hf-6m8	5.0.5	GHSA-f886-m6hf-6m8v: brace-expansion: Zero-step sequenc

... and 45 more high findings.

2.3 CI/CD and Infrastructure Findings

[CRITICAL] EOL runtime: nodejs 12 (1479 days past EOL)

node:12-alpine uses nodejs 12, which reached end-of-life on 2022-04-30 (1479 days ago). No security patches are being issued. Latest supported version: 12.22.12.

Fix: See TAARA recommendation

[CRITICAL] EOL runtime: nodejs 12 (1479 days past EOL)

node:12-alpine uses nodejs 12, which reached end-of-life on 2022-04-30 (1479 days ago). No security patches are being issued. Latest supported version: 12.22.12.

Fix: See TAARA recommendation

[CRITICAL] Action pinned to floating tag: actions/cache@v2

.github/workflows/e2e-test.yml line 26: 'actions/cache@v2' uses a tag, not a commit SHA. The tag can be moved to point at malicious code. This is exactly how the tj-actions attack worked in March 2025, compromising 23,000+ repositories. Fix: pin to the full commit SHA — uses: actions/cache

Fix: See TAARA recommendation

[CRITICAL] Action pinned to floating tag: actions/setup-node@v1

.github/workflows/e2e-test.yml line 21: 'actions/setup-node@v1' uses a tag, not a commit SHA. The tag can be moved to point at malicious code. This is exactly how the tj-actions attack worked in March 2025, compromising 23,000+ repositories. Fix: pin to the full commit SHA — uses: actions/

Fix: See TAARA recommendation

[CRITICAL] Action pinned to floating tag: actions/checkout@v2

.github/workflows/e2e-test.yml line 16: 'actions/checkout@v2' uses a tag, not a commit SHA. The tag can be moved to point at malicious code. This is exactly how the tj-actions attack worked in March 2025, compromising 23,000+ repositories. Fix: pin to the full commit SHA — uses: actions/ch

Fix: See TAARA recommendation

[CRITICAL] Action pinned to floating tag: actions/checkout@v2

.github/workflows/lint.yml line 16: 'actions/checkout@v2' uses a tag, not a commit SHA. The tag can be moved to point at malicious code. This is exactly how the tj-actions attack worked in March 2025, compromising 23,000+ repositories. Fix: pin to the full commit SHA — uses: actions/checko

Fix: See TAARA recommendation

[CRITICAL] Action pinned to floating tag: actions/upload-artifact@v2

.github/workflows/e2e-test.yml line 58: 'actions/upload-artifact@v2' uses a tag, not a commit SHA. The tag can be moved to point at malicious code. This is exactly how the tj-actions attack worked in March 2025, compromising 23,000+ repositories. Fix: pin to the full commit SHA — uses: act

Fix: See TAARA recommendation

[CRITICAL] Action pinned to floating tag: actions/setup-node@v1

.github/workflows/lint.yml line 21: 'actions/setup-node@v1' uses a tag, not a commit SHA. The tag can be moved to point at malicious code. This is exactly how the tj-actions attack worked in March 2025, compromising 23,000+ repositories. Fix: pin to the full commit SHA — uses: actions/setu

Fix: See TAARA recommendation

2.4 Exploit Chains — How an Attacker Gets In

Each chain shows the path from your application to a vulnerable package. Score 10 = direct critical vulnerability in a first-level dependency.

Attack Path	Score	CVE	Fix To
your application → async@2.6.1	10.0	GHSA-fwr7-v2mv-hh2	3.2.2
your application → bson@1.0.9	10.0	GHSA-v8w9-2789-6hh	1.1.4
your application → ms@0.7.1	10.0	GHSA-w9mr-4mfr-499	2.0.0
your application → minimist@1.2.0	10.0	GHSA-xvch-5gv4-984	1.2.6
your application → fsevents@1.2.9	10.0	GHSA-8r6j-v8pm-fqw	1.2.11
your application → tar@4.4.8	10.0	GHSA-3jq-g458-7qm	3.2.2
your application → tar@4.4.8	10.0	GHSA-5955-9wpr-37j	4.4.18
your application → tar@4.4.8	10.0	GHSA-83g3-92jg-28c	7.5.8

3. Server Security Analysis

3.1 Quantum Behavioral Fidelity

Metric	Value	Interpretation
F_min — angle encoding (primary)	0.4277	UNSAFE: genuine behavioral divergence
Threshold	0.5	Geometric midpoint of Hilbert space — parameter-free

4. Prioritised Action Plan

Generated from your actual findings — not generic advice:

THIS WEEK (24-72 hours)

- growl v1.9.2 (GHSA-qh2h-chj9-jffq): Update growl to version 1.10.0 using the command ``npm install growl@1.10.0`` to fix the critical vulnerability.
- handlebars v4.0.5 (GHSA-w457-6q6x-cgp9): Update handlebars to version 4.3.0 using the command ``npm install handlebars@4.3.0`` to fix the critical vulnerability.
- npm v3.10.10 (GHSA-ph34-pc88-72gc): Update npm to version 5.7.1 using the command ``npm install npm@5.7.1`` to fix the critical vulnerability.

THIS MONTH

- minimatch v3.0.4 (GHSA-7r86-cg39-jmmj): Update minimatch to the latest version using the command ``npm install minimatch@latest`` to fix the high-severity vulnerability, ensuring to test for any breaking changes.
- underscore v1.8.3 (GHSA-qpx9-hpmf-5gmw): Update underscore to version 1.12.1 using the command ``npm install underscore@1.12.1`` to fix the high-severity vulnerability.
- kind-of v6.0.2 (GHSA-6c8f-qphg-qjgp): Update kind-of to the latest version using the command ``npm install kind-of@latest`` to fix the high-severity vulnerability, ensuring to test for any breaking changes.

THIS QUARTER

- Implement a regular dependency update process to ensure that packages like set-value (currently at version 2.0.0 with a known vulnerability) and shelljs (currently at version 0.3.0 with a known vulnerability) are updated to their latest versions, such as set-value v2.0.1 and shelljs v0.8.5, to prevent similar critical vulnerabilities.
- Develop a comprehensive vulnerability monitoring and reporting system to track and address high-severity vulnerabilities like those found in minimatch v3.0.4 (GHSA-7r86-cg39-jmmj and GHSA-f8q6-p94x-37v3) and hawk v3.1.3 (GHSA-44pw-h2cw-w3vq), ensuring timely remediation and minimizing exposure.

5. What Continuous Monitoring Would Have Caught

This report is a point-in-time snapshot. The findings here existed before today — some of these CVEs have been public for years. The gap between a vulnerability existing and your team knowing about it can be months. TaaraWare closes that gap.

	Point-in-Time Audit (this report)	TaaraWare Continuous Monitoring
Detection lag	Months — until someone runs a scan	Under 10 minutes from occurrence
CVE coverage	Packages at scan time	Every new CVE checked against your stack automatically
Config drift	Not detected between scans	sshd_config, new ports, Dockerfile changes — real-time alert
Behavioral anomaly	Not detected	Quantum F_min computed continuously — alert at $F < 0.5$
CI/CD tampering	Caught only on rescan	GitHub Actions changes flagged on push
Agent response	Manual only	Pre-approved actions executed autonomously within autonomy policy

This scan found **46 critical vulnerabilities** across 165 findings. At IBM Cost of Data Breach India 2024 baseline of Rs. 2-5 Cr for MSMEs, a single breach from one critical finding costs more than years of continuous monitoring.

What TaaraWare Does Automatically

Action	Requires Approval?
Block SSH brute-force IP (>50 failures, 0 logins)	No — pre-approved policy
Alert: new public port opened	No — automated alert
Alert: sshd_config or Dockerfile changed	No — automated alert
New critical CVE in your installed packages	No — alert within 10 minutes
Quantum F_min drops below 0.5	No — agent proposes actions immediately
Rotate production secrets	Yes — always requires approval
Modify CI/CD pipeline	Yes — always requires approval

The difference between a point-in-time audit and continuous monitoring is the difference between finding a breach after and preventing it before.

Data Sources, Scope & Methodology

Scan target: <https://github.com/OWASP/NodeGoat>

Scan date: 2026-05-18

Packages checked: 1479 (via OSV.dev live API)

Quantum engine: PennyLane 4-qubit, dual encoding (amplitude + angle), ring-CNOT entanglement, F_min threshold 0.5 (parameter-free geometric midpoint)

PQC channel: ML-KEM Kyber768 (NIST FIPS 203) — TaaraWare↔CommandCenter

LLM analysis: Groq (llama-3.3-70b-versatile) — per-finding specific analysis

Data sources: OSV API (api.osv.dev), endoflife.date API, KB GraphRAG, lockfile parsing, dependency graph (networkx), GitHub Actions pattern analysis

Limitations: Point-in-time assessment — security posture changes continuously. OSV CVE data depends on package ecosystem coverage. This report does not constitute a penetration test. Quantum fidelity uses a PennyLane simulator — not real quantum hardware. Recommendations should be reviewed by a qualified professional before implementation.

*Generated by TAARA — Quantum Infrastructure Intelligence Platform
Report date: 2026-05-18 09:02 | TAARA Q.0 | GoodWinSun*